THREATLENS · ZEIT3118 · MODULE TEST REPORT

Quality Checker Scorecard

The quality checker was run across the full extractor corpus with the SQLite repository populated, so every dimension — including accuracy, which needs sighting counts — scored against real data for the first time.

Run **10 Sep 2026** Corpus **30 CTI reports** Verifier **qwen3.5:9b**

Extractor **cb5154d + 690416a** Checker **1a4123a + working** Tests **130 passed**

CORPUS

What was tested

1,246 Candidates assessed 30 reports	**578** Kept as indicators 46% of candidates	**249** Screened, not malicious 20% · stored at conf 0
212 Rejected as malformed 17%	**207** Context entities 17% · SDOs	**1,036** Sightings in database 1,006 indicators

Reports were handed to the checker as objects via `run_from_payload()`, the in-process path — no JSON round trip. The database was rebuilt from migrations, seeded, and loaded through the ingest layer before scoring.

SCORING · FOR ETHAN

How each metric performed

A metric earns its weight by separating good reports from bad. Distinct values is the honest test: a metric returning one value everywhere is weight spent on nothing.

DIMENSION	WEIGHT	VALUES SEEN	LEVELS	MEAN /5	VERDICT
Timeliness	0.25	1 · 2 · 3 · 4 · 5	5	3.11	healthy
Accuracy	0.30	1 · 2 · 3	3	1.05	live but thin
Completeness	0.25	0 · 2 · 3 · 5	4	1.97	key-limited
Relevance	0.20	1 · 2 · 3 · 4 · 5	5	4.78 / 1.22	healthy

Relevance means shown for a tactical / strategic reader. Consistency was removed this cycle and is no longer scored.

RESOLVED **Accuracy is no longer a constant**

Populating the repository gave accuracy real sighting counts. It now spans 1–3 instead of being pinned at 1 for every row. Corroboration exists but is sparse: 983 of 1,006 indicators appear in a single report, 21 in two, one in three (`ntdll.dll`) and one in eight (`persistence`). Thirty vendor reports on unrelated threats genuinely do not overlap much — the mechanism is proven; the corpus is what limits it.

RESOLVED **The score now separates reports**

Before this cycle the composite produced six distinct values across the corpus and two of five dimensions were constants. It now produces 20 distinct values over a 25–78 range for a tactical reader, with all four dimensions contributing.

LIMITATION **The practical ceiling is ~78, not 100**

Accuracy averaging 1.05 holds the top of the range down. A genuinely good report reads as 55–65. The dashboard should either normalise for display or label the scale, or readers will interpret a strong report as a failing grade.

LIMITATION **Two completeness keys rarely populate**

Of the four expected context keys, only `threat_actor` is reliably present (21/30 reports). `campaign` and `vulnerability` are unpopulatable in 27 of 30, `tool` in 25 of 30. Meanwhile `persistence` (9/30) and `ttp` (7/30) are populated but not counted. Completeness reached 5 exactly once, on *ta458 roundpress*.

DELIVERABLE

Report scores, as the end user sees them

Relevance is scored against the role the reader selects in the dashboard, so the same report carries two scores. The stored row keeps the audience profile as the durable fact; the dashboard recomputes per reader.

REPORT	PUBLISHED	AUDIENCE	IOCS	CISO / EXEC	ANALYST / DFIR
Amatera Stealer 4.0.2 Beta	2026-09-08	tactical 0.85	14	50.7	66.7
ta458 roundpress exploits	2026-07-15	mixed 0.54	17	58.0	58.0
Who Invited Aisuru to the LAN Party?	2026-08-18	tactical 0.95	22	40.2	56.2

REPORT	PUBLISHED	AUDIENCE	IOCS	CISO / EXEC	ANALYST / DFIR
Mirage Kitten targets Middle East	2026-07-28	tactical 0.89	40	40.2	56.2
Connection Between Xctdoor & ...	2026-08-03	tactical 0.89	35	40.1	56.1
Analysis of a Phishing Email Attack	2026-08-02	tactical 0.90	26	40.0	56.0
Borrowed Machinery: SnappyClient	2026-09-08	tactical 1.00	3	36.5	52.5
Cleaning Out Inboxes: TA488	2026-07-28	mixed 0.69	6	44.0	52.0
Head Mare / PhantomCore backdoors	2026-08-07	tactical 0.98	46	35.2	51.2
TELEPUZ modular MaaS malware	2026-07-16	tactical 0.94	83	35.2	51.2
Six npm Packages / Ethereum	2026-08-10	tactical 0.83	2	35.0	51.0
UNIT 42 Playbook Viewer	2026-08-10	tactical 0.99	75	35.0	51.0
Case Study: Targeted Attack on MSP	2026-07-24	tactical 0.97	23	35.0	51.0
Tracing an Underground Military Data Net	2026-08-07	mixed 0.77	8	41.8	49.8
Lx(Base) RAT: A Technical Deep Dive	2026-08-03	mixed 0.54	18	48.4	48.4
Dark Web Profile: ExfilSquad	2026-07-28	mixed 0.50	1	48.0	48.0
orova Ransomware Group Profile	2026-08-10	mixed 0.62	0	39.0	47.0
ModernStealer Threat Actor	2026-08-03	tactical 1.00	0	30.3	46.3
WordlistLoader Delivering Amatera	2026-08-18	tactical 1.00	48	30.0	46.0
Gunra Ransomware	2026-08-14	tactical 1.00	1	30.0	46.0
Credential harvesting that survives takedown	2026-09-02	tactical 0.97	25	30.0	46.0
Prompts as Code & Embedded Keys	2025-09-19	tactical 0.98	39	30.0	46.0
ACR Stealer: Two intrusion chains	2026-07-16	tactical 0.94	17	26.0	42.0
Shedding light on ABYSSWORKER driver	2025-03-20	tactical 0.92	6	25.0	41.0
How CrowdStrike Analyzes macOS Malware	2022-05-06	tactical 0.95	10	25.0	41.0
gammax Ransomware Group Profile	2026-08-09	mixed 0.26	0	47.0	39.0
Updated Cyber Threat Actor Naming System	2026-07-24	strategic 0.01	0	51.0	35.0
Governmental CERT	2022-04-01	tactical 1.00	11	15.0	31.0
North Korea-linked APT attack	2022-02-21	tactical 1.00	2	15.0	31.0
Dark Web Profile: ShinyHunters	2024-03-18	strategic 0.06	0	41.0	25.0

Sorted by analyst score. Bar is scaled to the analyst column. CISO min 15.0 / max 58.0 / mean 36.6 · Analyst min 25.0 / max 66.7 / mean 47.3.

WORKING **The role switch changes the answer, correctly**

Updated Cyber Threat Actor Naming System scores 51 for a CISO and 35 for an analyst — zero IoCs, pure policy content. *ShinyHunters* runs 41 against 25. Genuinely mixed reports score identically either way: *ta458* and *Lx(Base) RAT*, both profile 0.54, land on the same number for both readers. That is the right answer for a report that half-serves each audience.

WATCH **IoC count and score are independent by design**

TELEPUZ carries 83 indicators and scores 51.2; *Six npm Packages* carries 2 and scores 51.0. The score measures indicator quality, not volume. Surface both columns in the dashboard or users will read a small, well-sourced report outranking a large one as a bug.

EXTRACTION QUALITY · FOR BEN

What the checker caught

Every flag below is a candidate the extractor produced that did not survive assessment. Rates are per 100 candidates so they stay comparable as the corpus grows.

FLAG	COUNT	PER 100	WHAT IT MEANS
benign_observable	112	9.0	Real observable, not attacker infrastructure — victim domains, legitimate binaries
verifier_rejected	97	7.8	Well-formed, but the LLM judged it not an indicator
sentence_fragment	69	5.5	Span over-ran the entity into surrounding prose
span_overlap	59	4.7	Two candidates claim overlapping character ranges
invalid_format	45	3.6	Cannot populate its STIX type — e.g. `requests.get` as a domain
nested_value	43	3.5	Contains a shorter candidate that is the real entity
self_reference	34	2.7	The report's own publishing URL
duplicate_observable	17	1.4	Bare filename duplicating a filepath already captured
filename_as_domain	14	1.1	A filename matched by the domain rule
trailing_punctuation	12	1.0	Value ends in stray punctuation
not_stix_conformant	12	1.0	No legal STIX type for the extracted shape
truncated_span	7	0.6	Span began mid-token — value is shorter than the report published
known_benign	6	0.5	Matched the seeded allowlist
technique_idiom	6	0.5	Names a technique, not an artefact — e.g. `/dev/tcp`
unmapped_ioc_type	1	0.1	Type has no mapping into the database vocabulary

1,246 candidates across 30 reports. A candidate can carry more than one flag.

IMPROVED **Both fixes from the last cycle verified in the data**

AV signature names classified as domains dropped from 17 to 0 — the `SONAR.Ransom` / `Trojan.Gen` class is gone. `campaign` extracts again after being absent from all 16 previous reports, which is what lifted completeness off its band-4 ceiling. Normalised per candidate, `sentence_fragment` fell from 8.9 to 5.5 and `truncated_span` from 2.6 to 0.6.

OPEN **Span accuracy is still the largest single category**

`sentence_fragment`, `span_overlap`, `nested_value` and `trailing_punctuation` together account for 183 candidates — 14.7 per 100. All four are the same underlying issue: the regex span does not stop where the entity does.

OPEN **Seven values are shorter than what the report published**

`truncated_span` fires where the span began mid-token. The filepath rule anchors on a leading `/`, so `program/js/list.js.php` was stored as `/js/list.js.php` — a path a defender searching for it would never hit. The flag records the dropped prefix and the likely full value; it reports rather than repairs, so the defect stays visible rather than being silently rewritten.

NEXT

What each of us should pick up

BEN **Extraction engine**

1. Span termination — the four fragment/overlap flags are 14.7 per 100 candidates and share one root cause. Highest-value single fix available.
2. Filepath rule anchoring on `/` drops the leading path component. Seven confirmed cases; `truncated_span` detail carries the correct value for each.
3. `campaign` now extracts but only fires on 3 of 30 reports. If the naming-verb and `Operation X` patterns can widen, completeness lifts across the corpus.
4. Date parsing uses `date.today()`, which is local time — a report published today in a timezone ahead of the runner is silently rejected and scores timeliness 0.

ETHAN **Quality checker**

1. Completeness keys need re-picking against measured coverage: `threat_actor` 21/30, `persistence` 9/30, `ttp` 7/30, `tool` 5/30, `vulnerability` 3/30, `campaign` 3/30.
2. Decide how the dashboard presents a ~78 ceiling — normalise, or label the scale.
3. Accuracy strengthens only as the corpus grows. Worth agreeing a target report count before reading anything into it.
4. Consistency is removed from scoring but survives as a flag dimension label for traceability. Confirm that split is what the design doc should say.

TYLER **Database**

1. Ingest reported 9 conformance errors across the corpus — worth reviewing which candidates could not be mapped.
2. `scoring_config` now carries four dimensions summing to 1.00. Anyone with an existing database must re-run `python -m threatlens.db.seed` or the checker reads stale weights.
3. The stored score uses `ViewerRole.ANY`; the audience profile is the durable fact. Confirm the dashboard contract before wiring it.

METHOD

How to reproduce this

1 · rebuild	`alembic -c migrations/alembic.ini upgrade head` then `python -m threatlens.db.seed`
2 · ingest	`ingest_extraction_file(session, f)` for each file in `results/`
3 · sightings	`sighting_counts(session)`, keyed by `(ioc_type, normalised)`
4 · score	`check_report([run_from_payload(result)], policy, source_counts, role)`
policy	`ScoringPolicy.from_session(session)` — reads weights from the database, not the file

Generated from the working tree at commit `1a4123a` plus uncommitted quality-checker changes: consistency removed from scoring, role-aware relevance, weights rebalanced to sum to 1.00. 130 tests passing, lint clean on the `quality/` and `db/` packages.

Scores are quality-of-indicator measures, not a judgement of the source publication. A 2022 report scoring 31 is not a bad report — it is old, and timeliness carries a quarter of the weight.